

Offline Dictionary Attack on Password Authentication Schemes Using Smart Cards

Ding Wang^{1,2(✉)} and Ping Wang^{2,3}

¹ School of EECS, Peking University, Beijing 100871, China
wangding@mail.nankai.edu.cn

² National Engineering Research Center for Software Engineering,
Beijing 100871, China

³ School of Software and Microelectronics, Peking University, Beijing 100260, China
pwang@pku.edu.cn

Abstract. The design of secure and efficient smart-card-based password authentication schemes remains a challenging problem today despite two decades of intensive research in the security community, and the current crux lies in how to achieve truly two-factor security even if the smart cards can be tampered. In this paper, we analyze two recent proposals, namely, Hsieh-Leu's scheme and Wang's PSCAV scheme. We show that, under their non-tamper-resistance assumption of the smart cards, both schemes are still prone to offline dictionary attack, in which an attacker can obtain the victim's password when getting temporary access to the victim's smart card. This indicates that compromising a single factor (i.e., the smart card) of these two schemes leads to the downfall of both factors (i.e., both the smart card and the password), thereby invalidating their claim of preserving two-factor security. Remarkably, our attack on the latter protocol, which is not captured in Wang's original protocol security model, *reveals a new attacking scenario* and gives rise to the strongest adversary model so far. In addition, we make the first attempt to explain why smart cards, instead of common cheap storage devices (e.g., USB sticks), are preferred in most two-factor authentication schemes for security-critical applications.

[AQ1](#)

Keywords: Password authentication · Offline dictionary attack · Smart card · Common memory device · Non-tamper resistant

1 Introduction

Back in 1992, Bellare and Merritt [3] demonstrated how two parties, who only share a low-entropy password and communicate over a public network, can authenticate each other and agree on a cryptographically strong session key to secure their subsequent communications. Their work, known as encrypted key exchange, is a great success in protecting poorly-chosen passwords from the notorious offline dictionary attacks and thus confirms the feasibility of using password-only protocols to establish virtually secure channels over public networks, which is one of the main practical applications of cryptography. Due to the

practical significance of password-based authentication, Bellare-Meritt's seminal work has been followed by a number of remarkable proposals (e.g., [6, 7, 27]) with various levels of security and complexity.

While password authentication protocols are well suited to applications with moderate security demands, they are inadequate for use in security-critical applications such as e-banking, e-health and e-government [8]. Since password-based protocols generally require the server to store and manage a sensitive password-related file, a compromise of this file will lead to an exposure of the passwords of all the registered users, resulting in the downfall of the entire system. With the prevalence of zero-day attacks [4], these days it is no news to see the headlines about catastrophic leakages of tens of millions of passwords [13, 16]. It is due to this inherent limitation that two-factor authentication schemes¹ are introduced to enhance the systems' security and privacy. Owing to its portability, simplicity and cryptographic capability, smart-card-based password authentication has become one of the most effective, prevalent and promising two-factor authentication mechanisms.

Since Chang and Wu [9] developed the first smart-card-based password authentication scheme in 1991, there have been ample (in the hundreds) of this type of schemes proposed [15, 20, 23, 26, 28, 31, 48, 53, 57, 58]. Unfortunately, as stated in [34, 45], although there has been no lack of literature, it remains an immature area – all existing schemes are far from ideal and each has been shown to be either insecure or short of important features. For an intuitive grasp, we summarize the “break-fix-break-fix” history of this area in Fig. 1. Note that many other important schemes cannot be included here only due to space constraints.

Motivations. The past thirty years of research on password-only protocols have proved that it is incredibly difficult to get a single-factor protocol right [43, 60], while the past twenty years of “break-fix-break-fix” cycle of smart-card-based password protocols have manifested designing a two-factor scheme can only be harder [33, 34, 40]. It remains an open problem to construct an efficient and secure two-factor protocol that can meet all the security goals (see Sect. 2 of [54]) and preserve all the desirable features such as user anonymity and repairability (see [34] for a comprehensive list of desirable features).

We have analyzed more than one hundred and fifty smart-card-based password protocols and observe that, as with the domain of password-based single-factor authentication, offline dictionary attack is still the most prominent issue in two-factor authentication. This attack against many of previous protocols has emphasized the need for rigorous proofs of security in a formal, well-defined model. On the other hand, the practicality of a formal model largely depends on whether it “accurately captures the realistic capabilities of the adversary” [17]. As stated by Alfred Menezes [36, 37], although many formal security definitions “have an appealing logical elegance and nicely reflect certain notions of security, they fail to take into account many types of attacks and do not provide a comprehensive model of adversarial behavior”, and “the old-fashioned cryptanalysis continues to play an important role in establishing confidence in the security of a

¹ Note that the terms “protocol” and “scheme” will be used interchangeably thereafter.

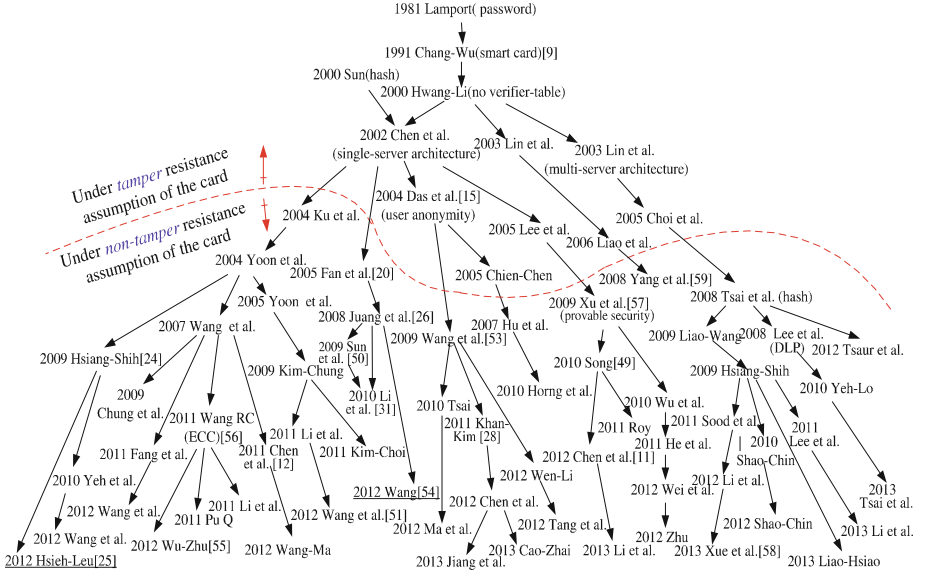


Fig. 1. A brief history of smart-card-based password authentication

cryptographic system”. All this and the continuous failures in designing a practical two-factor scheme outline the need for exploring the adversarial behaviors and for revealing the underlying subtleties by cryptanalysis.

Recent studies have pointed out that the secret parameters stored in common smart cards can be extracted by side-channel attacks such as power analysis [29, 38, 39] or reverse engineering techniques [35, 42]. Even though the card manufacturers may have considered the risks of side-channel attacks and provided countermeasures to cope with the problem, how much confidence can one have that these countermeasures residing in the card are still effective after three years of the card production and circulation? Considering this, since 2004 most schemes have preferred to use a non-tamper-resistant smart card (see the arcuate dash line of Fig. 1). This brings forth a question: While non-tamper resistance assumption has been made about smart cards (which means the core feature of the smart cards is lost), why not just use cheap memory devices (e.g., USB sticks) instead? As far as we know, little attention has been paid to this interesting (and fundamental) question.

Our Contributions. This paper examines the security of two recently proposed schemes, namely Hsieh-Leu’s scheme [25] and Wang’s PSCAV scheme [54]. These two schemes are the foremost ones and claimed to be secure against various known attacks. However, this work invalidates their claims by demonstrating that, under their assumption of the capabilities of the adversary, both schemes are vulnerable to the offline dictionary attack. This indicates that none of them can achieve the “precious” two-factor security.

Interestingly, our attack on Wang’s PSCAV scheme [54] highlights a new attacking scenario: Firstly, an attacker gets temporary access to the victim’s smart card and extracts its sensitive data (hereafter we say this card is exposed); Secondly, she returns the exposed card without awareness of the victim; Finally, she performs malicious attacks when the victim uses this exposed card. *This new attacking scenario has already given rise to the strongest adversary model so far* (see the “Returned stolen token” Section of [61]).

In addition, we take the first step toward giving a plausible explanation to the rather confusing question – why smart cards, instead of common cheap storage devices (e.g., USB sticks and flash-memory cards), are preferred in most two-factor authentication schemes for security-critical applications, even if smart cards can be tampered?

The remainder of this paper is organized as follows: Sect. 2 sketches the system architecture and elaborates on the adversary model; Then, Hsieh-Leu’s scheme is reviewed and analyzed in Sect. 3; In Sect. 4, we review Wang’s scheme and show its weakness; The conclusion is drawn in Sect. 5.

2 System Architecture and Adversary Models

2.1 System Architecture of Two-Factor Authentication

In this paper, we mainly focus on the most general case of two-factor authentication where the communication parties only involve a single server and a set of users, i.e. the traditional client/server architecture. It is not difficult to see that our results in this paper can be applied to more complex architectures where more than one server are involved, such as the multi-server authentication environments [58], the mobile network roaming environments [48] and the hierarchical wireless sensor networks [14].

In this sort of schemes, firstly the user chooses an identity (often as well as a password) and registers at the server; The server returns the user a smart card storing some security parameters. After registration, whenever the user wants to login to the server, she inserts the card into a terminal and enters her password. Then the card constructs a login request and sends it to the server. Upon receiving the request, the server checks its validity and will offer the requested service if the verification holds. Generally, a session key is established for securing the subsequent data communications. More sophisticated schemes also achieves mutual authentication, i.e. the client is also convinced that the server on the other end is authentic. What a truly two-factor protocol can guarantee is that, only the user who is in possession of both the smart card and the corresponding password can pass the verification of the server. This implies that a compromise of either factor will pose no danger to the security of a truly two-factor protocol.

2.2 Adversary Models for Smart-card-based Authentication and for Common-memory-based Authentication

In this section, we attempt to take the initial step to justify the use of smart cards rather than common memory devices in security-critical applications. Firstly,

we explicitly define the practical capabilities that an attacker may have in the smart-card-based authentication environment and in the memory-device-based authentication environment, respectively. Then, we investigate into the advantages and disadvantages of these two kinds of authentication.

Two Kinds of Mobile Devices. A smart card is an integrated circuit card with a processor for executing applications and a memory, coupled to the processor, for storing multiple applications. This kind of device has been widely used for various security-critical applications ranging from online-banking over digital rights management (DRM) to stream media (e.g., Pay-TV). For example, a HiPerSmart-P9SC648 smart card [47] from the 32-bit HiPerSmartTM family is of the RISC MIPS32 architecture, with a maximum clock speed of 36 MHz, a 512 Kbyte Flash, a 142 Kbyte EEPROM and a 16 Kbyte RAM. In the current market, such a smart card is priced at \$3.0 ~ 3.5. In contrast, a common USB memory stick is a data storage device that includes the flash memory with an integrated Universal Serial Bus (USB) interface, and the typical cost of an 1 GB USB stick is \$1.3 ~ 1.5 [21]. Since USB memory sticks² are not equipped with micro-processors, they cannot execute cryptographic operations as opposed to smart cards, and thus the operations have to be performed on the user terminal (e.g., PCs and PDAs).

As discussed in the previous section, it is prudent and reasonable to take into consideration the side-channel attacks [29, 38, 39, 42] when designing a smart-card-based two-factor authentication scheme. In other words, the secret data stored in the card memory are assumed to be extractable when the smart card is in the hands of an attacker. On the other hand, in the past it was just the tamper-resistant feature that makes smart cards prevail over other cheap (but non-tamper-resistant) memory devices. *Now that smart cards can be tampered, why we do not choose cheap USB memory sticks instead of expensive smart cards?* Or equally, what's the rationale under these propositions [20, 25, 31, 50, 51, 55, 57, 59] that endeavor to construct two-factor authentication schemes using non-tamper resistant smart cards rather than memory sticks? To the best of our knowledge, until now, little attention has been given to this question.

Two Kinds of Adversary Models. To identify the differences in security provisions offered by two-factor authentication schemes using these two different devices, we need to discuss the realistic capabilities that an attacker may have under these two different authentication environments. On the basis of the studies [50, 54, 57, 59], the following assumptions are made on the capabilities of the adversary $\mathcal{M}$ in the smart-card-based environment:

- S(i)** $\mathcal{M}$ can fully control the communication channel between the user and the server. In other words, she can inject, modify, block, and delete messages exchanged in the channel at will. This assumption is consistent with the Dolev-Yao model;

² Hereafter, we use “USB sticks” and “common memory devices” interchangeably. In this work, we do not consider hybrid devices like Trust Extension Devices [1].

- S(ii)** $\mathcal{M}$ is able to get access to the smart card and may compromise the user's smart card through side-channel attacks (only) when getting access to the smart card for a relatively long period of time (e.g., a few hours) [54, 59];
- S(iii)** $\mathcal{M}$ may compromise the user's password (e.g., by shoulder-surfing or malicious card reader [19, 32]).
- S(iv)** $\mathcal{M}$ is *not able to* extract the sensitive information on the smart card while intercepting the victim's password by using a malicious card reader, since the user is on the scene and the time is not sufficient for launching a side-channel attack [2, 54];
- S(v)** $\mathcal{M}$ is not allowed to first compromise the user's password (e.g., by shoulder-surfing) and then compromise the smart card [51, 54, 57]. Otherwise, no scheme can prevent $\mathcal{M}$ from succeeding. More specifically, if $\mathcal{M}$ has compromised both factors, there is no way to prevent $\mathcal{M}$ from impersonating the user, since it is these two factors together that precisely identifies the user. This is a trivial case.

The above Assumptions $S(i) \sim S(v)$ have been made in most recent schemes and their reasonableness is quite evident. For a detailed justification, readers are referred to [52]. It is worth noting that, Assumptions $S(ii)$ and $S(iv)$ together imply that the common non-tamper-resistance assumption made about the smart cards is *conditional*. In particular, it is Assumption $S(iv)$ that makes it possible for the smart-card-based schemes to be adopted in completely hostile environments, yet most studies [11, 20, 25, 28, 51, 57–59] (except few ones [52, 54]) do not make this assumption clear and just implicitly rely on it. Failing to catch this subtlety may cause great misconceptions and lead to curious situations as it did in the works [10, 44, 45, 59], which will be discussed later in this section.

Regarding USB-stick-based schemes, Assumption $S(iv)$ will not be valid, because it is not difficult for a malware to copy all the contents in the USB memory stick within only seconds, even if the user appears on the scene. Nevertheless, the other four assumptions do roughly hold for common-memory-based environment:

- M(i)** $\mathcal{M}$ can fully control the communication channel between the user and the server. In other words, she can inject, modify, block, and delete messages exchanged in the channel at will. This assumption is consistent with the Dolev-Yao model;
- M(ii)** $\mathcal{M}$ is able to compromise the user's memory device through malware within a short time period (e.g., in a few seconds);
- M(iii)** $\mathcal{M}$ may compromise the user's password (e.g., by shoulder-surfing or social engineering);
- M(iv)** $\mathcal{M}$ is *able to* extract the sensitive data on the memory device while intercepting the password that the user input by using malwares;
- M(v)** $\mathcal{M}$ is not allowed to first compromise the user's password and then compromise the user's memory device. Clearly, if $\mathcal{M}$ compromises both factors, there is no way to prevent $\mathcal{M}$ from impersonating the user, since these two factors together precisely identify the user. It is a trivial case.

Justification for Using Smart Cards. Having examined the differences of adversary models between the smart card scenario and the common memory device scenario, we proceed to look into the rationales underlying the wide use of smart cards rather than common memory devices in two-factor authentication.

Recently, with the popularity of mobile devices, a few studies [10, 44] advocated the use of common memory devices instead of smart cards to construct two-factor schemes, and claimed that their schemes can “enjoy all the advantages of authentication schemes using smart cards” [44]. However, such a claim is a bit optimistic. According to the above adversary model for common-memory-device environment, such a claim holds only when the scheme is adopted in a trusted user terminal (otherwise, the malicious terminal could just intercept the password and copy the content of the memory device, and with no doubt the attacker is able to impersonate the victim in future). Smart-card-based schemes, in contrast, do not subject to this restriction. For example, under the five assumptions $S(i) \sim S(v)$, Wang et al. [52] manage to construct a smart-card-based scheme with provable security, and this scheme can well operate in a hostile user terminal.

In contrast to the optimistic view of [10, 44], the work in [45] pessimistically stated that, if the smart card are assumed to be non-tamper-resistant, then “it is no better than a passive token”. Consequently, smart cards are abandoned in their choice and static clonable tokens are in place, and a software-only two-factor scheme is proposed. Obviously, according to our above analysis, such a software-only scheme can never achieve the same level of security as compared to smart-card-based schemes. Nevertheless, this scheme may be suitable for applications where costs gain more concerns than security. The authors in [59] also explicitly advocate that they “do not make assumption on the existence of any special security features supported by the smart-cards” and “simply consider a smart-card to be a memory card with an embedded micro-processor for performing required operations specified in a scheme.” It is not difficult to see that, in the light of their statements, their proposed smart-card-based scheme [59] can never achieve the claimed two-factor security.

In security-critical applications, user terminals are often the targets of attackers and may be infected with viruses, trojans and malwares, only two-factor authentication schemes using smart cards (which is though only conditionally tamper-proof) are suitable for such environments, common-memory-device-based two-factor schemes *cannot* “enjoy all the advantages of authentication schemes using smart cards”. This explicates why most studies adhere to use smart cards rather than common memory devices when designing two-factor schemes (which is made for security-critical applications), even if it is supposed that the data stored in the card memory can be extracted.

3 Cryptanalysis of Hsieh-Leu’s Scheme

In 2012, Hsieh and Leu [25] demonstrated several attacks against Hsiang-Shih’s [24] smart-card-based password authentication scheme. To remedy the identified

security flaws, they proposed an enhanced version over Hsiang-Shih's scheme [24] by "exploiting hash functions", and claimed that their improved scheme can withstand offline dictionary attack even if the sensitive parameters are extracted by the adversary. However, as we will show in the following, under their non-tamper-resistance assumption of the smart cards, Hsieh-Leu's scheme is still vulnerable to offline dictionary attack, which is similar to the one that Hsiang-Shih's scheme suffers.

3.1 A Brief Review of Hsieh-Leu's Scheme

For ease of presentation, we employ some intuitive notations as listed in Table 1 and will follow the descriptions in Hsieh-Leu's scheme [25] as closely as possible. This scheme is composed of four phases: registration, login, verification and password change.

Table 1. Notations and abbreviations

Symbol	Description
U_i	i^{th} user
S	remote server
$\mathcal{M}$	malicious attacker
ID_i	identity of user U_i
PW_i	password of user U_i
x	the secret key of remote server S
$\oplus$	the bitwise XOR operation
$\parallel$	the string concatenation operation
$h(\cdot)$	collision free one-way hash function
$A \rightarrow B : C$	message C is transferred through a common channel from A to B
$A \Rightarrow B : C$	message C is transferred through a secure channel from A to B

Registration Phase. In this phase, the initial registration is different from the re-registration. Since the re-registration process has little relevance with our discussions, it is omitted here. The initial registration is depicted as follows.

- (1) U_i chooses a random number b and computes $h(b \oplus PW_i)$.
- (2) $U_i \Rightarrow S : ID_i, h(PW_i), h(b \oplus PW_i)$.
- (3) On receiving the login request, in the account database, server S creates an entry for U_i and stores $n = 0$ in this entry.
- (4) S computes $EID = (h(ID_i) \parallel n)$, $P = h(EID \oplus x)$, $R = P \oplus h(b \oplus PW_i)$ and $V = h(h(PW_i) \oplus h(x))$, and stores V in the entry corresponding to U_i .
- (5) $S \Rightarrow U_i : a$ smart card containing R and $h(\cdot)$.
- (6) On receiving the smart card, U_i inputs b into his smart card and does not need to remember b since then.

Login Phase. When user U_i wants to login to S , she inserts her smart card into the card reader and keys her ID_i with PW_i . The smart card performs the following steps:

- (1) The smart card computes $C_1 = R \oplus h(b \oplus PW_i)$ and $C_2 = h(C_1 \oplus T_i)$, where T_i denotes U_i 's current timestamp.
- (2) $U_i \rightarrow S : \{ID_i, T_i, C_2\}$.

Verification Phase. On receiving the login request from U_i , the remote server S and U_i 's smart card perform the following steps:

- (1) If either ID_i or T_i is invalid or $T_s - T_i \leq 0$, S rejects U_i 's login request. Otherwise, S computes $C'_2 = h(h(EID \oplus x) \oplus T_i)$, and compares C'_2 with the received C_2 . If they are equal, S accepts U_i 's login request and proceeds to compute $C_3 = h(h(EID \oplus x) \oplus h(T_s))$, where T_s denotes S 's current timestamp. Otherwise, U_i 's login request is rejected.
- (2) $S \rightarrow U : \{T_s, C_3\}$.
- (3) If either T_s is invalid or $T_s = T_i$, U_i terminates the session. Otherwise, U_i computes $C'_3 = h(C_1 \oplus h(T_s))$, and compares the computed C'_3 with the received C_3 . If they are equal, U_i authenticates S successfully.

Password Change Phase. When U_i wants to update her password, this phase is employed. Since this phase has little relevance with our discussions, it is omitted.

3.2 Offline Dictionary Attack

Offline dictionary attack is the most damaging threat that a practical password-based protocol must be able to guard against [3, 27]. Hsieh and Leu showed that Hsiang-Shih's scheme [24] is vulnerable to offline dictionary attack once the secret parameters stored in the victim's smart card are revealed by the adversary "by monitoring the power consumption or by analyzing the leaked information".

Now let's see how exactly the same attack could be successfully launched with Hsieh-Leu's own scheme in place. Suppose user U_i 's smart card is somehow (stolen or picked up) in the possession of an adversary $\mathcal{M}$, and the parameters R and b can be revealed using side-channel attacks [35, 38]. With the previously intercepted authentication transcripts $\{ID_i, C_2, T_i\}$ from the public channel, $\mathcal{M}$ can obtain U_i 's password PW_i as follows:

- Step 1.* Guesses the value of PW_i to be PW_i^* from the dictionary space $\mathcal{D}_{pw}$.
- Step 2.* Computes $C_1^* = R \oplus h(b \oplus PW_i^*)$, where R, b is extracted from U_i 's smart card.
- Step 3.* Computes $C_2^* = h(C_1^* \oplus T_i)$, where T_i is previously intercepted from the public channel.
- Step 4.* Verifies the correctness of PW_i^* by checking if the computed C_2^* is equal to the intercepted C_2 .

Step 5. Repeats Step 1 $\sim$ 4 of this procedure until the correct value of PW_i is found.

Our attack shows that once the smart-card factor is compromised, the corresponding password factor can be offline guessed and hence the entire system collapses. This indicates that Hsieh-Leu’s scheme is intrinsically not a two-factor scheme and is as insecure as the original scheme (i.e., Hsiang-Shih’s scheme [24]). This also corroborates the “public-key principle” [33] that, under the non-tamper resistance assumption of the smart cards, only symmetric-key techniques (such as Hash, block cipher) are inherently unable to resist offline dictionary attack.

Let $|\mathcal{D}_{pw}|$ denote the number of passwords in $\mathcal{D}_{pw}$. The time complexity of the above attack procedure is $\mathcal{O}(|\mathcal{D}_{pw}| * (2T_H + 3T_X))$, where T_H is the running time for Hash function and T_X the running time for bitwise XOR operation. It is easy to see that, the time for $\mathcal{M}$ to recover U_i ’s password is a linear function of the number of passwords in the password space. And hence our attack is quite effective. For an intuitive grasp of the effectiveness of this attack (and the following attack on PSCAV), we further obtain the running time (see Table 2) for the related operations on common Laptop PCs by using the publicly-available, multi-precision integer and rational arithmetic C/C++ library MIRACL [46]. In practice, the password space is very limited, e.g., $|\mathcal{D}_{pw}| \leq 10^6$ [5, 18, 56], and it follows that the above attack can be completed in seconds on a common PC.

Table 2. Computation evaluation of related operations on common Laptop PCs

Experimental platform (common PCs)	Exponentiation T_E ($ n =1024$)	Symmetric encryption T_S (AES-128)	Hash operation T_H (SHA-1)	Other lightweight operations(e.g.,XOR)
Intel T5870 2.00 GHz	10.526 ms	2.012 μ s	2.437 μ s	0.011 μ s
Intel E5500 2.80 GHz	7.716 ms	0.530 μ s	0.756 μ s	0.009 μ s
Intel i5-3210 2.50 GHz	4.390 ms	0.415 μ s	1.132 μ s	0.008 μ s

The above attack can be generalized as follows: with the security parameters extracted from the smart card and the transcripts intercepted during the previous login session(s), the attacker can repeatedly guess the victim’s password via an offline automated program. This attack strategy is not new. Actually, it is the common “Waterloo” of many broken schemes [11, 12, 24, 28, 49]. This attack scenario (adversary behavior) has been captured in several two-factor security models [54, 55, 57]. Yet, the following attacker is still at large.

4 Cryptanalysis of PSCAV from SEC 2012

In SEC’12, Wang [54] observed that the previous papers in this area present attacks on protocols in earlier works and put forward new proposals without proper security justification (let alone a security model to fully identify the practical threats), which constitutes the main cause of the long-standing failure. Accordingly, Wang presented three kinds of security models, namely Type I, II

and III. In the Type III model, which is the harshest model, mainly three assumptions are made:

- (1) an adversary $\mathcal{M}$ is allowed to have full control of the communication channel between the user and the server;
- (2) the smart card is assumed to be non-tamper resistant and the user's password may be intercepted by $\mathcal{M}$ using a malicious smart card reader, but not both;
- (3) there is no counter protection in the smart card, i.e. $\mathcal{M}$ can issue a large amount of queries to the smart card using a malicious card reader to learn some useful information.

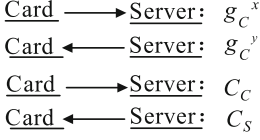
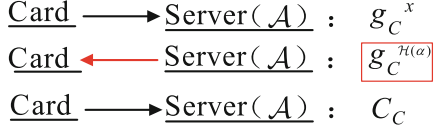
Note that, the above Assumption 1 accords with **S(i)**, and Assumption 2 is consistent with **S(ii)~S(v)** (see Sect. 2.2). As for Assumption 3, its opposite is implicitly made in most of previous schemes as well as the model introduced in Sect. 2.2. Apparently, a scheme which is secure in Type III shall also be secure in a model only with Assumptions 1 and 2. To the best of our knowledge, the Type III model is the strongest model that has ever been proposed for smart-card-based password authentication so far.

Wang [54] further proposed four schemes, only two of which, i.e. PSCAb and PSCAV, are claimed to be secure under the Type III model. However, PSCAb requires Weil or Tate pairing operations to defend against offline dictionary attack and may not be suitable for systems where pairing operations are considered to be too expensive or infeasible to implement. Moreover, PSCAb suffers from the well-known key escrow problem and lacks some desirable features such as repairability, user anonymity and local password update. As for PSCAV, in this paper, we will show that it is susceptible to offline dictionary attack under Assumptions 1 and 2 (or equally, **S(ii)~S(v)**) plus a new (but realistic) assumption – the attacker can return a victim's exposed card without detection.

4.1 A Brief Review of PSCAV

In this section, we firstly give a brief review of PSCAV and then present the attack. Here we just follow the original notations in [54] as closely as possible. Assume that the server has a master secret β (β could be user specific also). For each user (or called client) C with identity $\mathcal{C}$ and password α , let the user specific generator be $g_C = \mathcal{H}(\mathcal{C}, \alpha, \beta)$, the value $g_C^{\mathcal{H}_2(\alpha)} (= \mathcal{E}_{\mathcal{H}_2(\alpha)}(g_C))$, and thus $g_C = \mathcal{D}_{\mathcal{H}_2(\alpha)}(g_C^{\mathcal{H}_2(\alpha)})$ is stored in the smart card, where $\mathcal{H}$ and $\mathcal{H}_2$ are two independent hash functions, and $\mathcal{E}/\mathcal{D}$ stand for symmetric encryption/decryption (see Sect. 3.2 of [54]). The value $g_C = \mathcal{H}(\mathcal{C}, \alpha, \beta)$ will be stored in the server's database for this user. The remaining of the protocol runs as follows:

- (1) The card selects random x , computes $g_C = \mathcal{D}_{\mathcal{H}_2(\alpha)}(g_C^{\mathcal{H}_2(\alpha)})$ and sends $R_A = g_C^x$ to the server;
- (2) Server selects random y and sends $R_A = g_C^y$ to the card;
- (3) The card computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$ and $sk = g_C^{y(x+u)}$, where $\mathcal{S}$ is identity string of the server;

**Fig. 2.** Message flows of PSCAV**Fig. 3.** Our attack

- (4) The card sends $C_C = \mathcal{H}(sk, \mathcal{C}, \mathcal{S}, R_A, R_B, 1)$ to the server;
- (5) After verifying that C_C is correct, the server computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$, $sk = g_C^{y(x+u\alpha)} = (g_C^x)^y \cdot g_C^{yu\alpha} = (R_A)^y \cdot g_C^{yu\alpha}$, and sends $C_S = \mathcal{H}(sk, \mathcal{S}, \mathcal{C}, R_B, R_A, 2)$ to the card.

The message flows of PSCAV are shown in the Fig. 2. Since the session key sk is computed with the contribution of the password α by server S in the above Step 5, the password α (or the parameter g_C^α) is needed to be known by S . However, the original specification in [54] does not explicitly explain how can the server obtain the user's password α to compute sk in the above Step 5. We assume (suggest) g_C^α is also stored in the server's database, i.e. an entry $(\mathcal{C}, g_C, g_C^\alpha)$ corresponding to user $\mathcal{C}$ is stored in the server's database.³ This ambiguity does not affect our security analysis however.

4.2 Offline Dictionary Attack

Suppose an adversary $\mathcal{M}$ has got temporary access to the client C 's smart card and obtained the stored secret $g_C^{\mathcal{H}_2(\alpha)}$. Then $\mathcal{M}$ sends back the card without awareness of the victim C . Once C uses the exposed smart card, the attacker can impersonate as the server to interact with C and to learn C 's password. The attack, as summarized in Fig. 3, can be carried out by $\mathcal{M}$ as follows:

- Step 1.* On intercepting $R_A = g_C^x$ from client C , $\mathcal{M}$ blocks it and sends $R_B = g_C^{\mathcal{H}_2(\alpha)}$ to the client on behalf of the server, where $g_C^{\mathcal{H}_2(\alpha)}$ is extracted from C 's card;
- Step 2.* On receiving the response C_C , $\mathcal{M}$ computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$.
- Step 3.* Guesses the value of password α to be α^* from dictionary $\mathcal{D}_{pw}$.
- Step 4.* Computes $g_C^* = \mathcal{D}_{\mathcal{H}_2(\alpha^*)}(g_C^{\mathcal{H}_2(\alpha)})$;
- Step 5.* Computes $sk^* = g_C^{x\mathcal{H}_2(\alpha^*)} \cdot (g_C^*)^{u\alpha^*\mathcal{H}_2(\alpha^*)}$
 $= (R_A)^{\mathcal{H}_2(\alpha^*)} \cdot (g_C^*)^{u\alpha^*\mathcal{H}_2(\alpha^*)}$;
- Step 6.* $\mathcal{M}$ computes $C_C^* = \mathcal{H}(sk^*, \mathcal{C}, \mathcal{S}, R_A, R_B, 1)$;
- Step 7.* Verifies the correctness of α^* by checking if the computed C_C^* is equal to the received C_C ;
- Step 8.* Repeats the above Steps 3–8 until the correct value of α is found.

The time complexity of the above attack is $\mathcal{O}(|\mathcal{D}_{pw}| * (3T_E + T_S + 3T_H))$. As the size of the password dictionary, i.e. $|\mathcal{D}_{pw}|$, is very limited in practice

³ This ambiguity and our suggested remedy have been confirmed by the author of [54], and he earns our deep respect for his frankly and quickly acknowledgement.

[5, 18, 56], e.g. $|\mathcal{D}_{pw}| \leq 10^6$, the above attack can be completed in polynomial time. Further considering the experimental timings listed in Table 2, $\mathcal{M}$ may recover the password in minutes on a PC by a single run of PSCAV.

Interestingly, our attack on Wang’s PSCAV scheme [54] highlights *a new attacking scenario*: Firstly, an attacker gets temporary access to the victim’s card and extracts its security parameters; Secondly, she sends back the exposed card without awareness of the victim; Finally, she performs malicious attacks when the victim uses this exposed card. Note that this attacking scenario is quite realistic. For example, an employee accidentally leaves her bank card on her desk after work, the attacker picks this card and performs the side-channel attacks herself (or with recourse to professional labs) in the evening and puts it back before the victim comes to work the next morning. The victim will find no abnormality and use this card as usual. Unfortunately, once this card is put to use, the corresponding password may be leaked, while the above procedure well serves to illustrate how the password can be leaked to an attacker. As reported in [41], “agencies are interested in quickly accessing someone’s room, install some bug in the her mobile device and then return it without detection”. This also confirms the practicality of our attack.

Wang’s PSCAV scheme is secure in their security model yet vulnerable to our new attacking strategy. Since the identified attacking scenario is realistically oriented towards a serious threat, it deserves special attention when defining the underlying security model for smart-card-based password authentication. This once again suggests that, a good security model is not one that denies the capabilities of the attacker but rather one designed to capture the attacker’s practical abilities as comprehensively as possible, and the powers not allowed to the attacker are those that would allow her to trivially break any of this type of schemes [22, 30]. Fortunately, *our observation has already given rise to the strongest adversary model so far*: Just two weeks ago, a new security model named Type III-r was developed in [61].

5 Conclusion

Understanding security pitfalls of cryptographic protocols is the key to both patching existing protocols and designing future schemes. In this paper, we have demonstrated that Hsieh-Leu’s scheme and Wang’s PSCAV scheme suffer from the offline dictionary attack under two different attacking strategies, which reveals the challenges in constructing a practical authentication scheme with truly two-factor security. Remarkably, our attack on Wang’s PSCAV scheme highlights a new realistic attack scenario and thus uncovers a new behavior of the attacker – returning the exposed smart card without awareness of the victim. As for future work, we are considering designing a practical scheme that can survive in the Type III-r model.

Acknowledgment. We are grateful to Prof. Yongge Wang from UNC Charlotte, USA, for the constructive discussions and Prof. David Naccache for referring us to [41]. This

research was partially supported by the National Natural Science Foundation of China under No. 61472016.

References

1. Asokan, N., Ekberg, J.-E., Kostiaainen, K.: The untapped potential of trusted execution environments on mobile devices. In: Sadeghi, A.-R. (ed.) FC 2013. LNCS, vol. 7859, pp. 293–294. Springer, Heidelberg (2013)
2. Barengi, A., Breveglieri, L., Koren, I., Naccache, D.: Fault injection attacks on cryptographic devices: theory, practice, and countermeasures. *Proc. IEEE* **100**(11), 3056–3076 (2012)
3. Bellare, S.M., Merritt, M.: Encrypted key exchange: password-based protocols secure against dictionary attacks. In: *Proceedings IEEE S&P 1992*, pp. 72–84. IEEE (1992)
4. Bilge, L., Dumitras, T.: Before we knew it: an empirical study of zero-day attacks in the real world. In: *Proceedings ACM CCS 2012*, pp. 833–844. ACM (2012)
5. Bonneau, J.: The science of guessing: analyzing an anonymized corpus of 70 million passwords. In: *Proceedings IEEE S&P 2012*, pp. 538–552. IEEE Computer Society (2012)
6. Boyd, C., Montague, P., Nguyen, K.: Elliptic curve based password authenticated key exchange protocols. In: Varadharajan, V., Mu, Y. (eds.) ACISP 2001. LNCS, vol. 2119, p. 487. Springer, Heidelberg (2001)
7. Bresson, E., Chevassut, O., Pointcheval, D.: New security results on encrypted key exchange. In: Bao, F., Deng, R., Zhou, J. (eds.) PKC 2004. LNCS, vol. 2947, pp. 145–158. Springer, Heidelberg (2004)
8. Burr, W., Dodson, D., Perlner, R., Polk, W., Gupta, S., Nabbus, E.: NIST Special Publication 800–63-1: Electronic Authentication Guideline. National Institute of Standards and Technology, Gaithersburg (2011)
9. Chang, C.C., Wu, T.C.: Remote password authentication with smart cards. *IEE Proc. Comput. Digital Tech.* **138**(3), 165–168 (1991)
10. Chen, B.L., Kuo, W.C., Wu, L.C.: A secure password-based remote user authentication scheme without smart cards. *Inf. Technol. Control* **41**(1), 53–59 (2012)
11. Chen, B.L., Kuo, W.C., Wu, L.C.: Robust smart-card-based remote user password authentication scheme. *Int. J. Commun. Syst.* **27**(2), 377–389 (2014)
12. Chen, T.H., Hsiang, H.C., Shih, W.K.: Security enhancement on an improvement on two remote user authentication schemes using smart cards. *Future Gener. Comput. Syst.* **27**(4), 377–380 (2011)
13. Constantin, L.: Sony stresses that PSN passwords were hashed. Online news (2011). <http://news.softpedia.com/news/Sony-Stresses-PSN-Passwords-Were-Hashed-198218.shtml>
14. Das, M.L.: Two-factor user authentication in wireless sensor networks. *IEEE Trans. Wirel. Commun.* **8**(3), 1086–1090 (2009)
15. Das, M., Saxena, A., Gulati, V.: A dynamic id-based remote user authentication scheme. *IEEE Trans. Consum. Electron.* **50**(2), 629–631 (2004)
16. Dazzlepod Inc.: CSDN cleartext passwords. Online news (2013). <http://dazzlepod.com/csdn/>
17. Degabriele, J.P., Paterson, K., Watson, G.: Provable security in the real world. *IEEE Secur. Priv.* **9**(3), 33–41 (2011)
18. Dell’Amico, M., Michiardi, P., Roudier, Y.: Password strength: an empirical analysis. In: *Proceedings INFOCOM 2010*, pp. 1–9. IEEE (2010)

19. Drimer, S., Murdoch, S.J., Anderson, R.: Thinking inside the box: system-level failures of tamper proofing. In: *Proceedings IEEE S&P 2008*, pp. 281–295. IEEE (2008)
20. Fan, C., Chan, Y., Zhang, Z.: Robust remote authentication scheme with smart cards. *Comput. Secur.* **24**(8), 619–628 (2005)
21. Focus Technology Co., Ltd: Prices for 1GB Usb Flash Drive (2013). http://www.made-in-china.com/products-search/hot-china-products/1gb-Usb_Flash_Drive.html
22. Hao, F.: On robust key agreement based on public key authentication. In: Sion, R. (ed.) *FC 2010*. LNCS, vol. 6052, pp. 383–390. Springer, Heidelberg (2010)
23. He, D., Ma, M., Zhang, Y., Chen, C., Bu, J.: A strong user authentication scheme with smart cards for wireless communications. *Comput. Commun.* **34**(3), 367–374 (2011)
24. Hsiang, H., Shih, W.: Weaknesses and improvements of the yoon-ryu-yoo remote user authentication scheme using smart cards. *Comput. Commun.* **32**(4), 649–652 (2009)
25. Hsieh, W., Leu, J.: Exploiting hash functions to intensify the remote user authentication scheme. *Comput. Secur.* **31**(6), 791–798 (2012)
26. Juang, W.S., Chen, S.T., Liaw, H.T.: Robust and efficient password-authenticated key agreement using smart cards. *IEEE Trans. Industr. Electron.* **55**(6), 2551–2556 (2008)
27. Katz, J., Ostrovsky, R., Yung, M.: Efficient and secure authenticated key exchange using weak passwords. *J. ACM* **57**(1), 1–41 (2009)
28. Khan, M., Kim, S.: Cryptanalysis and security enhancement of a more efficient & secure dynamic id-based remote user authentication scheme. *Comput. Commun.* **34**(3), 305–309 (2011)
29. Kim, T.H., Kim, C., Park, I.: Side channel analysis attacks using am demodulation on commercial smart cards with seed. *J. Syst. Soft.* **85**(12), 2899–2908 (2012)
30. Krawczyk, H.: HMQV: A high-performance secure Diffie-Hellman protocol. In: Shoup, V. (ed.) *CRYPTO 2005*. LNCS, vol. 3621, pp. 546–566. Springer, Heidelberg (2005)
31. Li, X., Qiu, W., Zheng, D., Chen, K., Li, J.: Anonymity enhancement on robust and efficient password-authenticated key agreement using smart cards. *IEEE Trans. Ind. Electron.* **57**(2), 793–800 (2010)
32. Long, J.: *No Tech Hacking: A Guide to Social Engineering, Dumpster Diving, and Shoulder Surfing*. Syngress, Burlington (2011)
33. Ma, C.G., Wang, D., Zhao, S.: Security flaws in two improved remote user authentication schemes using smart cards. *Int. J. Commun. Syst.* **27**(10), 2215–2227 (2014)
34. Madhusudhan, R., Mittal, R.: Dynamic id-based remote user password authentication schemes using smart cards: a review. *J. Netw. Comput. Appl.* **35**(4), 1235–1248 (2012)
35. Mangard, S., Oswald, E., Popp, T.: *Power Analysis Attacks: Revealing the Secrets of Smart Cards*. Springer, Heidelberg (2007)
36. Menezes, A.: Another look at HMQV. *J. Math. Cryptol.* **1**(1), 47–64 (2007)
37. Menezes, A.: Another look at provable security. In: Pointcheval, D., Johansson, T. (eds.) *EUROCRYPT 2012*. LNCS, vol. 7237, pp. 8–8. Springer, Heidelberg (2012)
38. Messerges, T.S., Dabbish, E.A., Sloan, R.H.: Examining smart-card security under the threat of power analysis attacks. *IEEE Trans. Comput.* **51**(5), 541–552 (2002)
39. Moradi, A., Barengi, A., Kasper, T., Paar, C.: On the vulnerability of FPGA bitstream encryption against power analysis attacks: extracting keys from xilinx Virtex-II FPGAs. In: *Proceedings ACM CCS 2011*, pp. 111–124. ACM (2011)

40. Murdoch, S.J., Drimer, S., Anderson, R., Bond, M.: Chip and pin is broken. In: Proceedings IEEE Security & Privacy 2010, pp. 433–446. IEEE Computer Society (2010)
41. Naccache, D.: National security, forensics and mobile communications. In: Won, D.H., Kim, S. (eds.) ICISC 2005. LNCS, vol. 3935, pp. 1–1. Springer, Heidelberg (2006)
42. Nohl, K., Evans, D., Starbug, S., Plötz, H.: Reverse-engineering a cryptographic rfid tag. In: Proceedings USENIX Security 2008, pp. 185–193. USENIX Association (2008)
43. Pointcheval, D.: Password-based authenticated key exchange. In: Fischlin, M., Buchmann, J., Manulis, M. (eds.) PKC 2012. LNCS, vol. 7293, pp. 390–397. Springer, Heidelberg (2012)
44. Rhee, H.S., Kwon, J.O., Lee, D.H.: A remote user authentication scheme without using smart cards. *Comput. Stan. Interfaces* **31**(1), 6–13 (2009)
45. Scott, M.: Replacing username/password with software-only two-factor authentication. Technical report, Cryptology ePrint Archive, Report 2012/148 (2012). <http://eprint.iacr.org/2012/148.pdf>
46. Shamus Software Ltd.: Miracl library (2013). <http://www.shamus.ie/index.php?page=home>
47. Smart Card Alliance: Philips Advances Smart Card Security for Mobile Applications (2013). <http://www.ceic-cn.org/files/NXP2006zcard.pdf>
48. Son, K., Han, D., Won, D.: A privacy-protecting authentication scheme for roaming services with smart cards. *IEICE Trans. Commun.* **95**(5), 1819–1821 (2012)
49. Song, R.: Advanced smart card based password authentication protocol. *Comput. Stan. Interfaces* **32**(5), 321–325 (2010)
50. Sun, D.Z., Huai, J.P., Sun, J.Z.: Improvements of juang et al.'s password-authenticated key agreement scheme using smart cards. *IEEE Trans. Industr. Electron.* **56**(6), 2284–2291 (2009)
51. Wang, D., Ma, C., Wu, P.: Secure password-based remote user authentication scheme with non-tamper resistant smart cards. In: Cuppens-Boulahia, N., Cuppens, F., Garcia-Alfaro, J. (eds.) DBSec 2012. LNCS, vol. 7371, pp. 114–121. Springer, Heidelberg (2012)
52. Wang, D., Ma, C., Wang, P., Chen, Z.: Robust smart card based password authentication scheme against smart card security breach. In: Cryptology ePrint Archive, Report 2012/439 (2012). <http://eprint.iacr.org/2012/439.pdf>
53. Wang, Y., Liu, J., Xiao, F., Dan, J.: A more efficient and secure dynamic id-based remote user authentication scheme. *Comput. Commun.* **32**(4), 583–585 (2009)
54. Wang, Y.: Password protected smart card and memory stick authentication against off-line dictionary attacks. In: Gritzalis, D., Furnell, S., Theoharidou, M. (eds.) SEC 2012. IFIP AICT, vol. 376, pp. 489–500. Springer, Heidelberg (2012)
55. Wu, S.H., Zhu, Y.F., Pu, Q.: Robust smart-cards-based user authentication scheme with user anonymity. *Secur. Commun. Netw.* **5**(2), 236–248 (2012)
56. Wu, T.: A real-world analysis of kerberos password security. In: Proceedings NDSS 1999, pp. 13–22. Internet Society (1999)
57. Xu, J., Zhu, W., Feng, D.: An improved smart card based password authentication scheme with provable security. *Comput. Stand. Inter.* **31**(4), 723–728 (2009)
58. Xue, K., Hong, P., Ma, C.: A lightweight dynamic pseudonym identity based authentication and key agreement protocol without verification tables for multi-server architecture. *J. Comput. Syst. Sci.* **80**(1), 195–206 (2014)
59. Yang, G., Wong, D., Wang, H., Deng, X.: Two-factor mutual authentication based on smart cards and passwords. *J. Comput. Syst. Sci.* **74**(7), 1160–1172 (2008)

60. Zhao, Z., Dong, Z., Wang, Y.G.: Security analysis of a password-based authentication protocol proposed to IEEE 1363. *Theoret. Comput. Sci.* **352**(1), 280–287 (2006)
61. Zhao, Z., Wang, Y.G.: Secure communication and authentication against off-line dictionary attacks in smart grid systems (2013). <http://coitweb.uncc.edu/yonwang/papers/smartgridfull.pdf>